Ingeniería en Desarrollo de Software

Actividad | 3 | Cross Site (XSS)

Ingeniería en Desarrollo de Software



TUTOR: Jessica Hernández.

ALUMNO: Uziel de Jesús López Ornelas.

FECHA: 13 de octubre de 2026.

Tabla de contenido

Introducción **1**

Descripción **1**

Justificación **2**

Desarrollo **2**

Etapa 1 2

Descripción del sitio web 2

Ataque al sitio 3

Etapa 2 7

Ataque al sitio 7

Etapa 3 24

Ataque al sitio 24

Conclusión **33**

Link de GitHub 33

Introducción

Nuestra materia de Auditoría Informática nos enseña que proteger la privacidad de nuestros datos es muy importante, porque así evitamos fugas de información sensible que puedan afectar tanto el ámbito personal como el empresarial.

Esta actividad final se basó en dos entregas previas:

* Actividad 1: Consistió en seleccionar una página web y utilizar el software Wireshark para analizar el flujo de tráfico en la red y capturar en texto plano las credenciales ingresadas en el sitio.

* Actividad 2: Se utilizó el software Burp Suite para acceder a un laboratorio mediante su navegador integrado y realizar pruebas de vulnerabilidad con el fin de acceder como administrador.

Con base en ello llegamos a la Actividad 3, donde, utilizando el mismo software de la segunda entrega, realizaremos una alteración en las credenciales que se envían a la página web trabajada en la primera actividad.

La guía nos solicita tomar capturas de pantalla paso a paso de lo que va sucediendo e integrar también el contenido de las actividades anteriores. Posterior a esto, debemos crear nuestro repositorio y guardar la entrega en formato PDF. Es importante recordar que este procedimiento se realiza sobre páginas no cifradas (HTTP), ya que en sitios con protocolo HTTPS el tráfico no se mostrará de esta manera al estar completamente cifrado.

Descripción

Esta actividad crea un entorno práctico donde probamos vulnerabilidades asociadas a la manipulación de peticiones y Cross-Site Scripting (XSS). Al ingresar credenciales a través del navegador integrado de Burp Suite, estas se capturan en el proxy antes de llegar al servidor. Esto nos permite alterar el usuario y la contraseña para que el sistema los detecte como erróneos e impida el acceso al sitio.

El flujo de trabajo se desarrolla de la siguiente manera:

* Al ingresar las credenciales en el navegador y presionar el botón de login o ingresar, la página quedará en espera debido a que la petición está siendo interceptada por el software.

* Si no modificamos ningún parámetro y seleccionamos la opción de continuar (Forward), el proxy enviará la solicitud original y la página abrirá normalmente al ser la información correcta.

* Por el contrario, si ingresamos las credenciales correctas, pero interceptamos la petición y alteramos el usuario o la contraseña por datos fijos incorrectos, al reenviar la solicitud la página cargará

rechazando el acceso debido a la modificación realizada.

Toda esta documentación estará respaldada con evidencias en captura de pantalla completa para verificar la autoría del trabajo y distinguirlo claramente de entregas de otros alumnos de la universidad.

Justificación

El análisis de vulnerabilidades en sistemas y páginas web es de suma relevancia en la actualidad. Una auditoría informática permite verificar que una empresa cumpla con los estándares de seguridad necesarios para evitar filtraciones que afecten sus procesos o comprometan su reputación.

A través de esta práctica se comprende la importancia de mantener un control estricto en:

* Los inicios y cierres de sesión.

* La modificación de datos y el acceso a credenciales.

* La implementación de mecanismos de autenticación avanzados (como biometría por huella dactilar o iris) para reforzar la confidencialidad en las bases de datos.

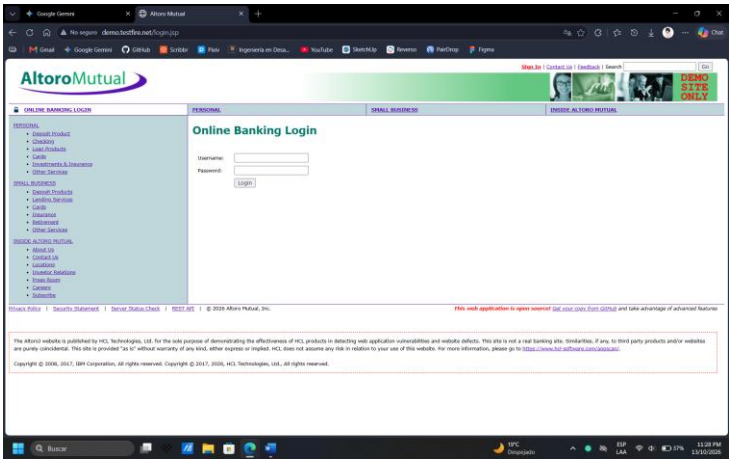
Asimismo, es fundamental que las organizaciones implementen políticas de desarrollo seguro de código. En arquitecturas ramificadas o conectadas a un eje central, la falla o vulnerabilidad de un solo componente puede impactar a toda la infraestructura; por ello, todos los módulos deben comunicarse de forma correcta para mitigar riesgos sobre la información.

Desarrollo

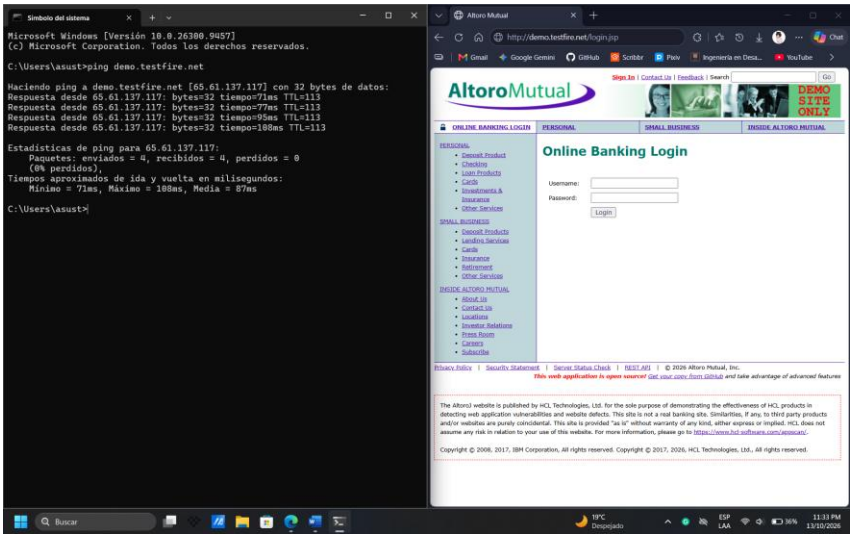
Etapa 1

Descripción del sitio web

Usaremos la siguiente página que nos servirá para las pruebas de login, con esto tendremos lo necesario:

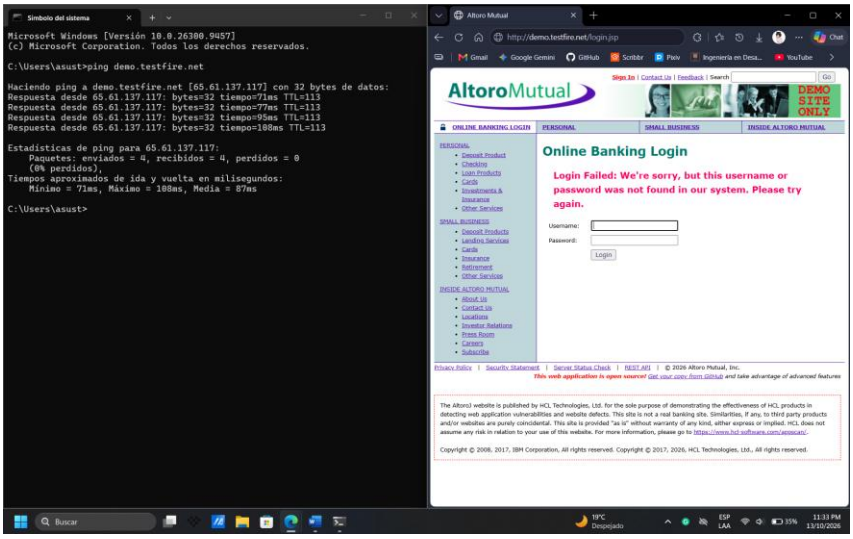


Usaremos el comando “Ping” para obtener la dirección IP de la página:

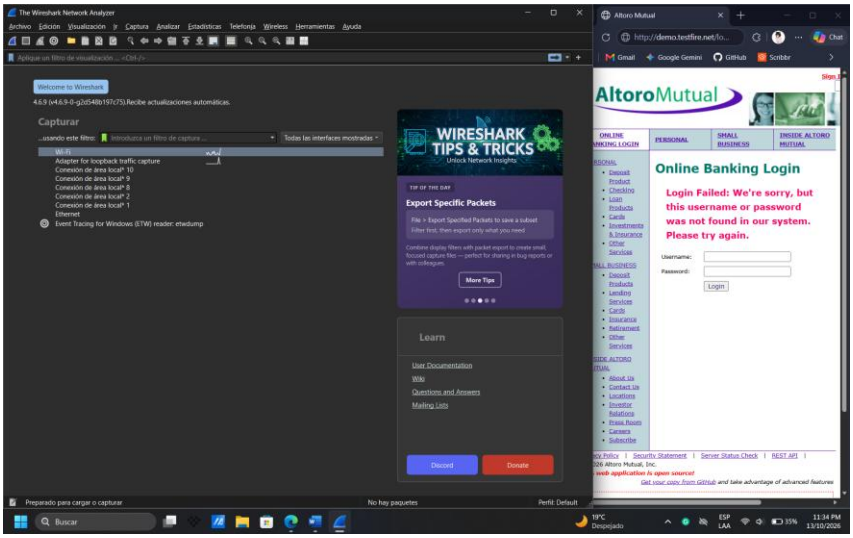


Ataque al sitio

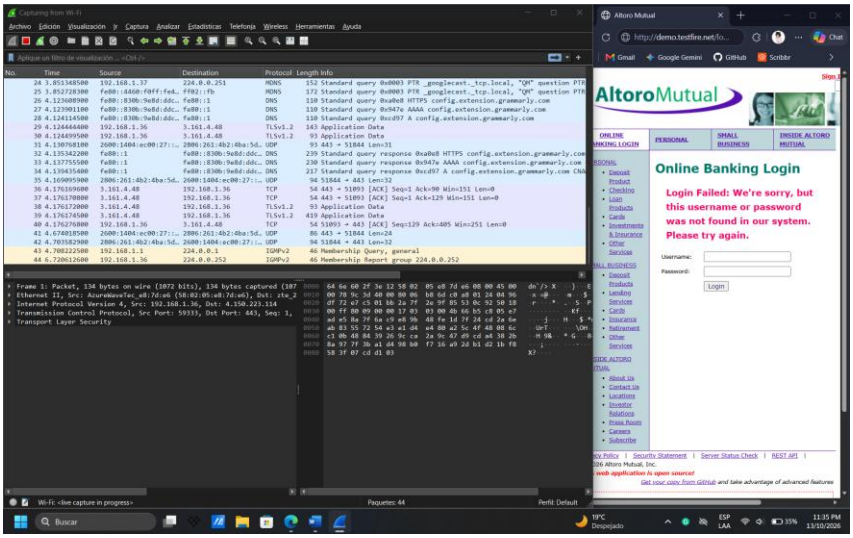
En la misma página vamos a colocar datos incorrectos:



Ingresamos al panel principal de Wireshark:



Entramos a la opción de Wifi, en este lugar podemos ver el tráfico en tiempo real:

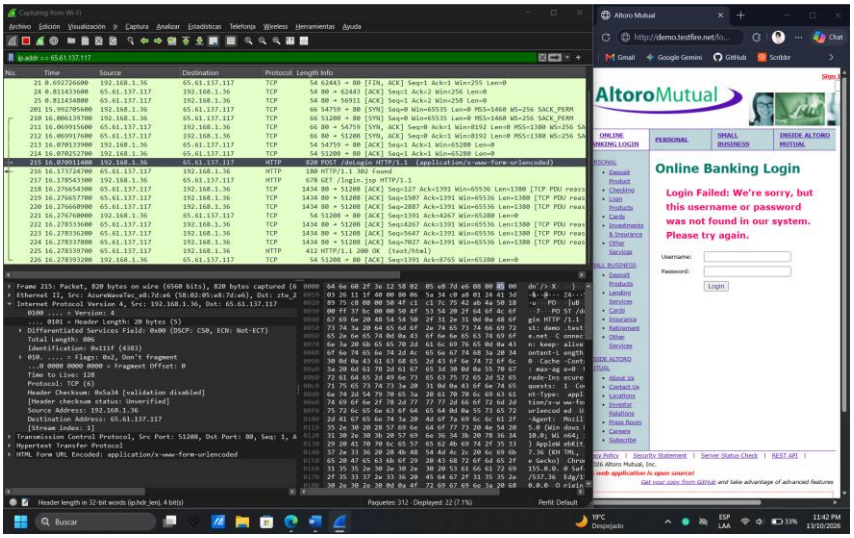


Nos dirigimos a Wireshark para colocar en el filtro la dirección IP, al colocar lo siguiente:

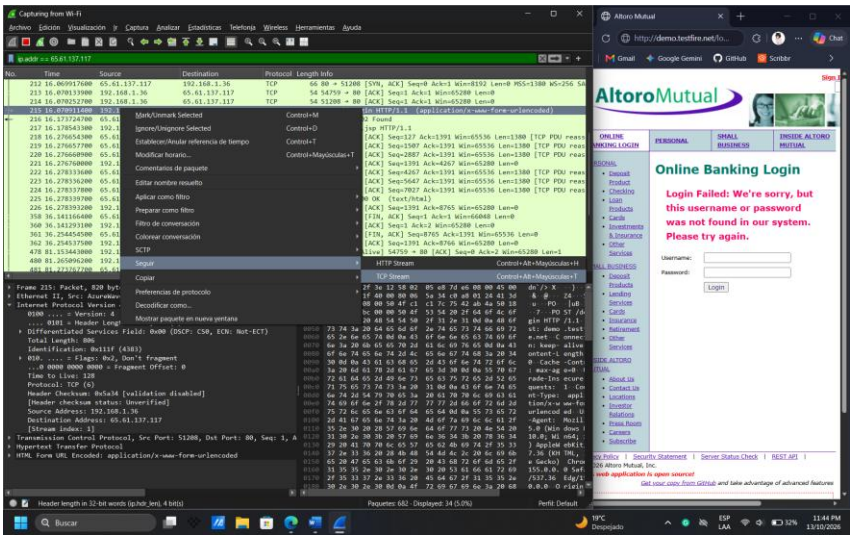
-**Usuario**: LeyzuSD.

-**Contraseña**: 998877.

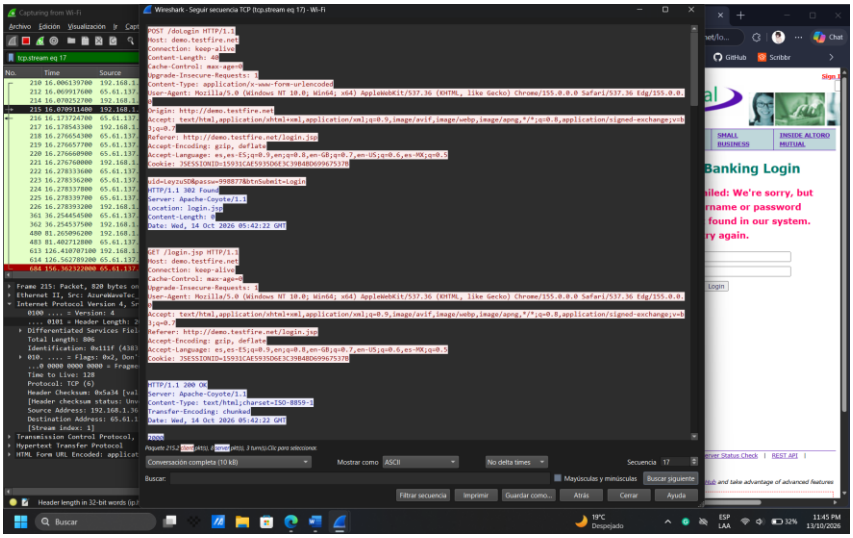
Nos marca un error pero este ya esta guardado en Wireshark.



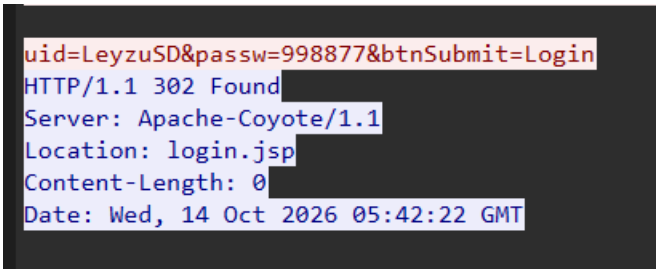
Seguiremos el protocolo para acceder a la información que se colocó anteriormente:



Nos aparecerá lo siguiente:



Todo esto es una secuencia de caracteres que nos muestra la información que colocamos en el **Login** y en el **Password**, si analizamos con mas detalle podemos ver una línea interesante:

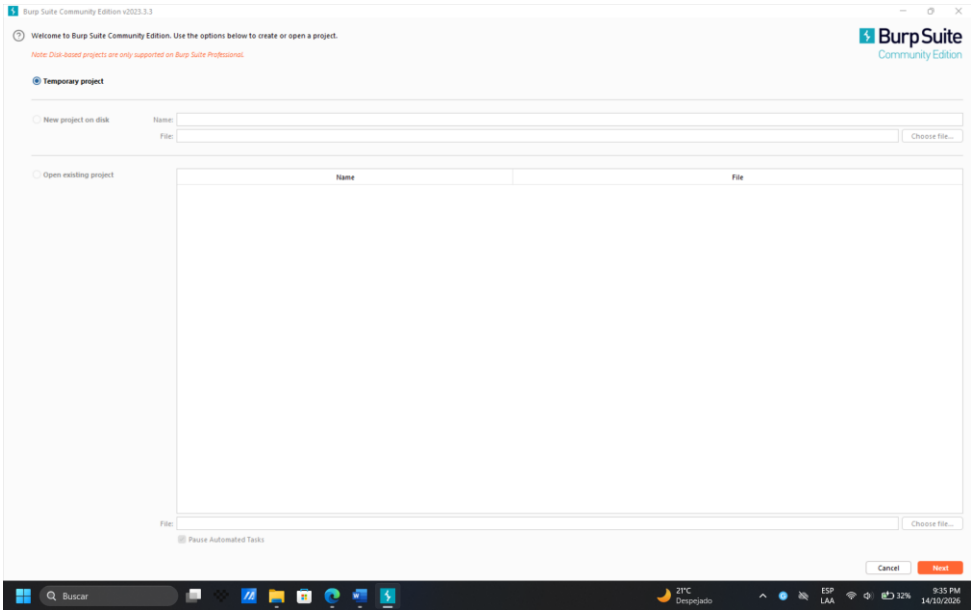


Lo anterior concuerda con el usuario y contraseña que habíamos colocado anteriormente. Con esto tenemos la actividad realizada de acuerdo a los pasos que se nos dio.

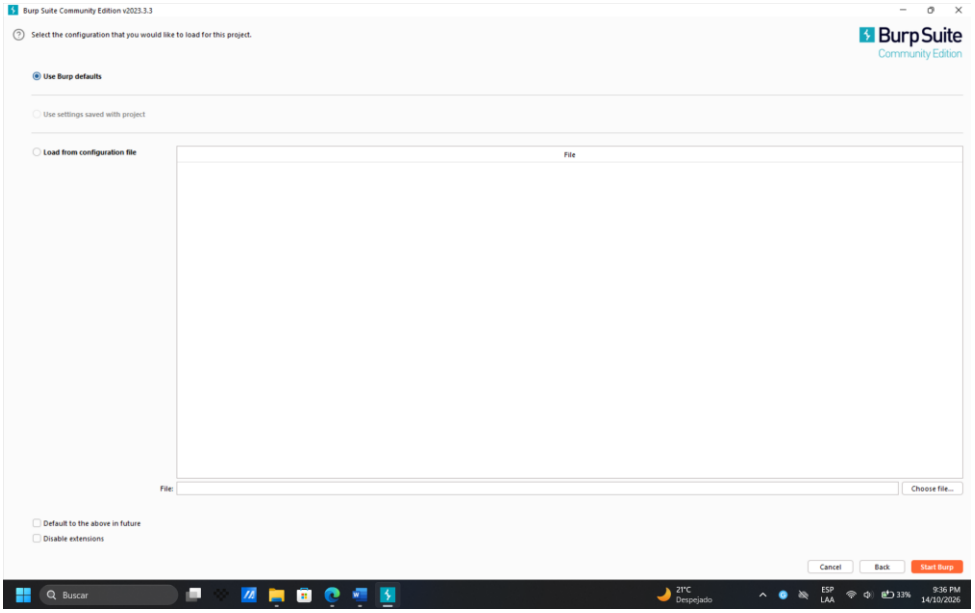
Etapa 2

Ataque al sitio

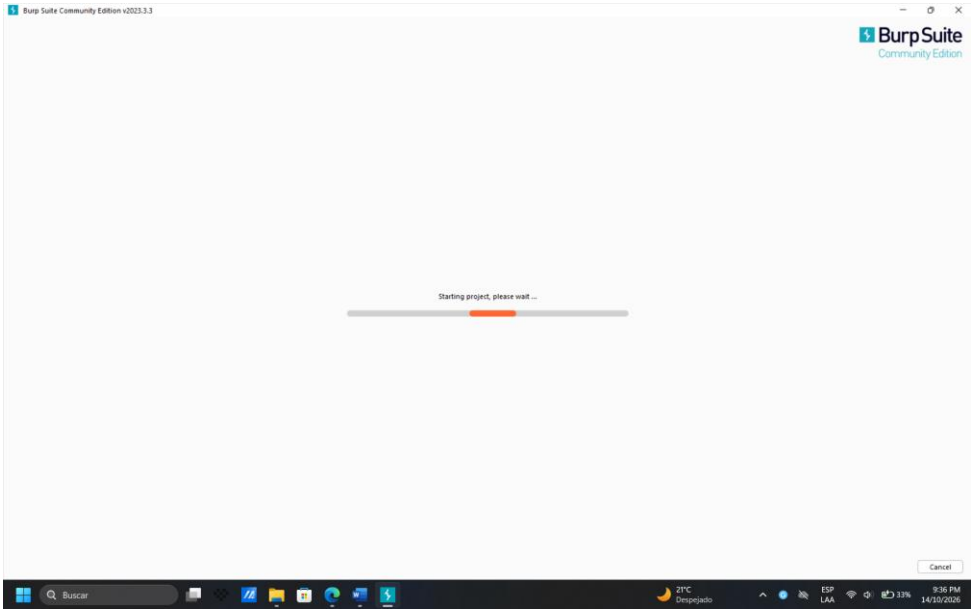
Vamos a abrir el software de Burp Suite que tenemos descargado gracias al material de estudio:



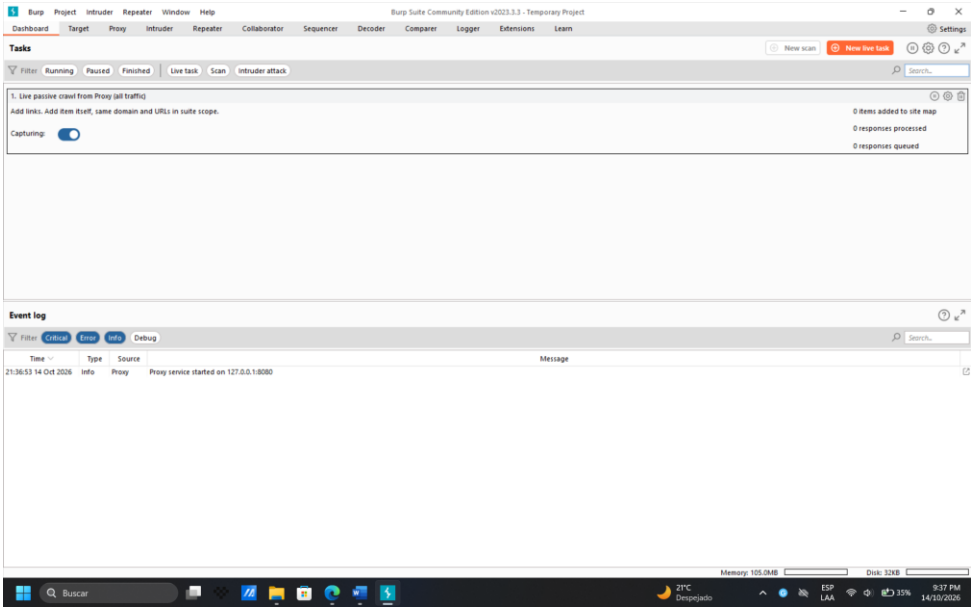
Seleccionamos Next que nos mandara a una ventana distinta:



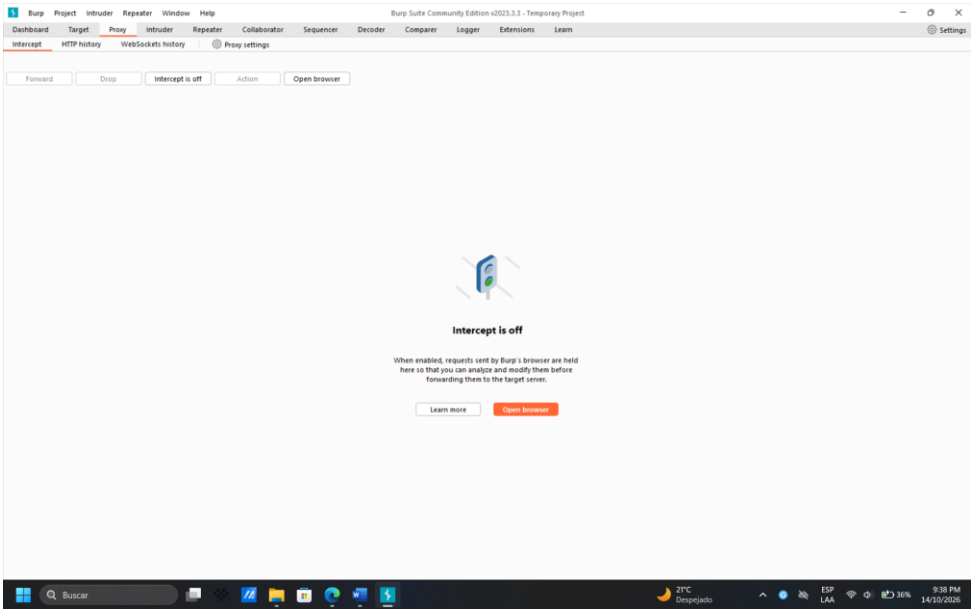
Con ello listo vamos a seleccionar ahora Start Burp, se nos cargara una ventana para preparar todo:



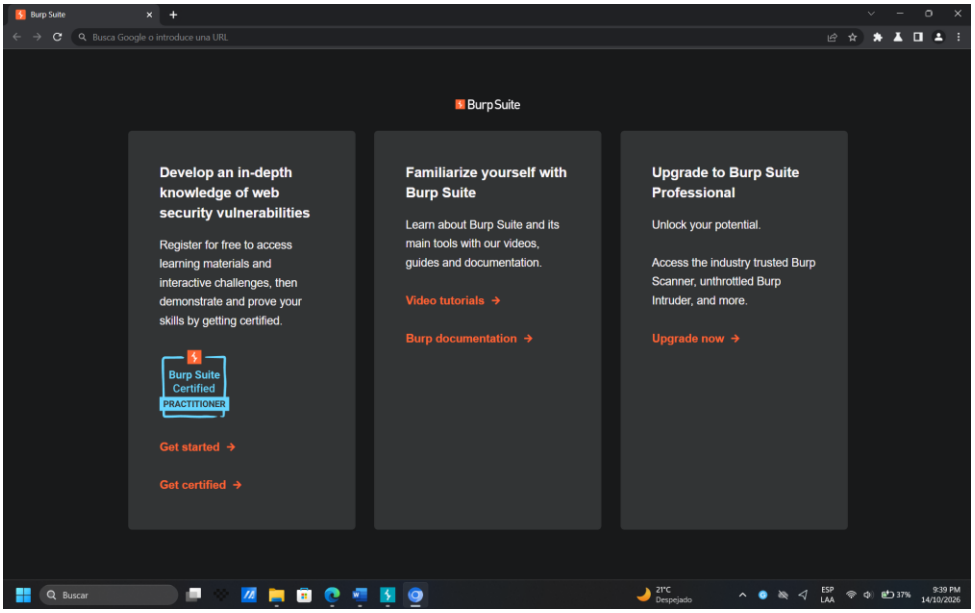
Esta es nuestra pantalla de control:



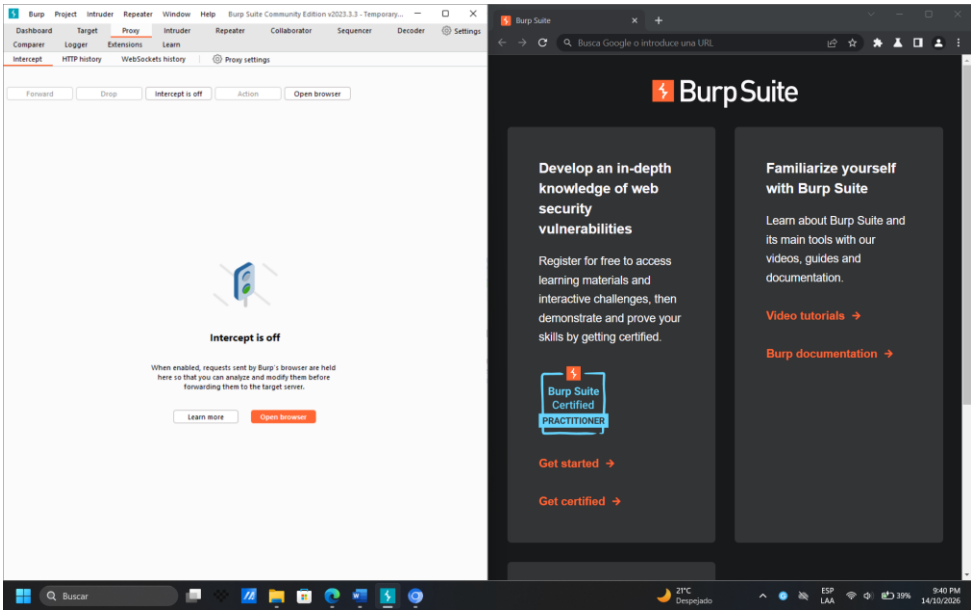
Nos vamos a dirigir a la pestaña de Proxy:



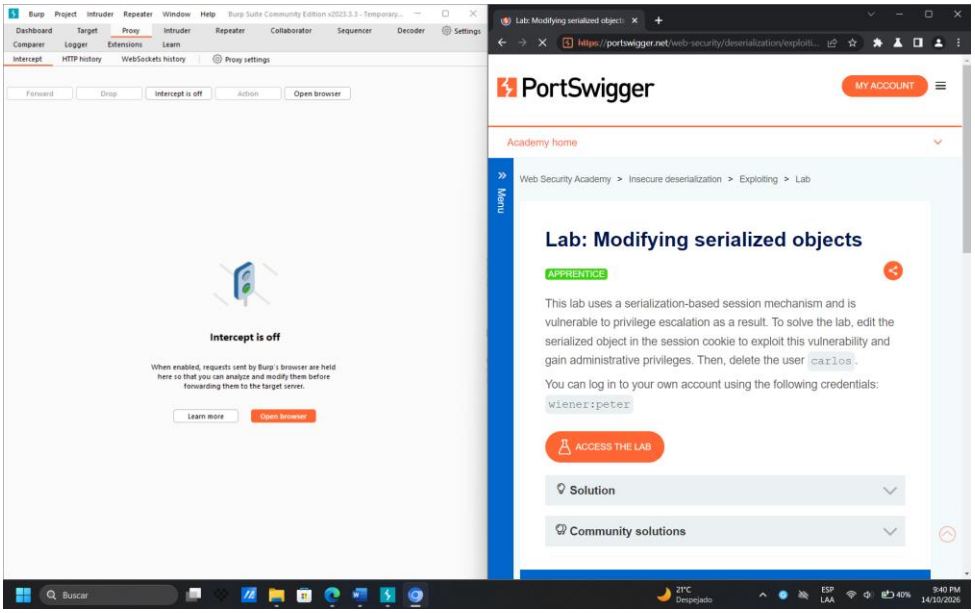
Presionaremos el botón de Open Browser y se nos abrirá el navegador:



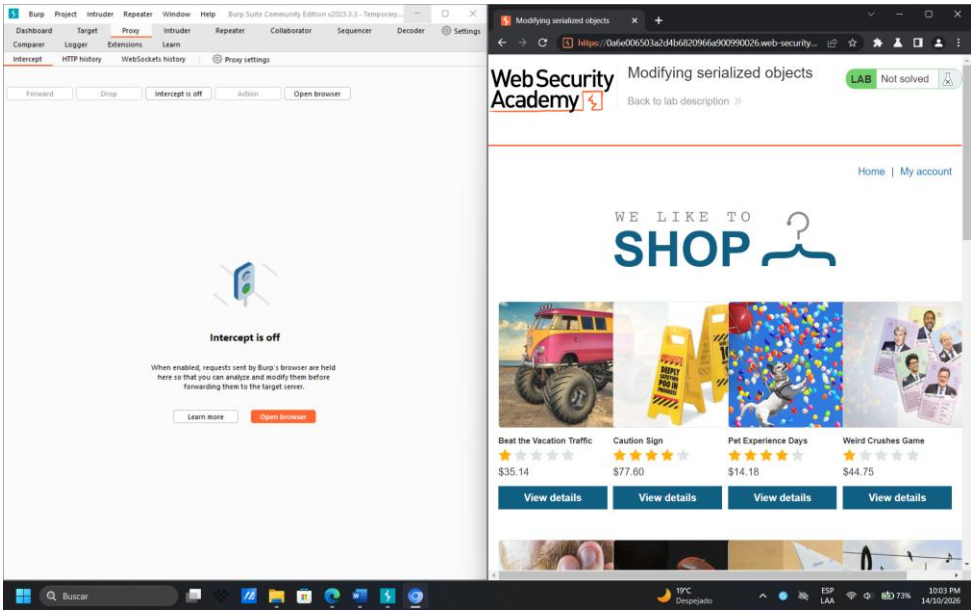
Dividimos la pantalla para tener mejor control:



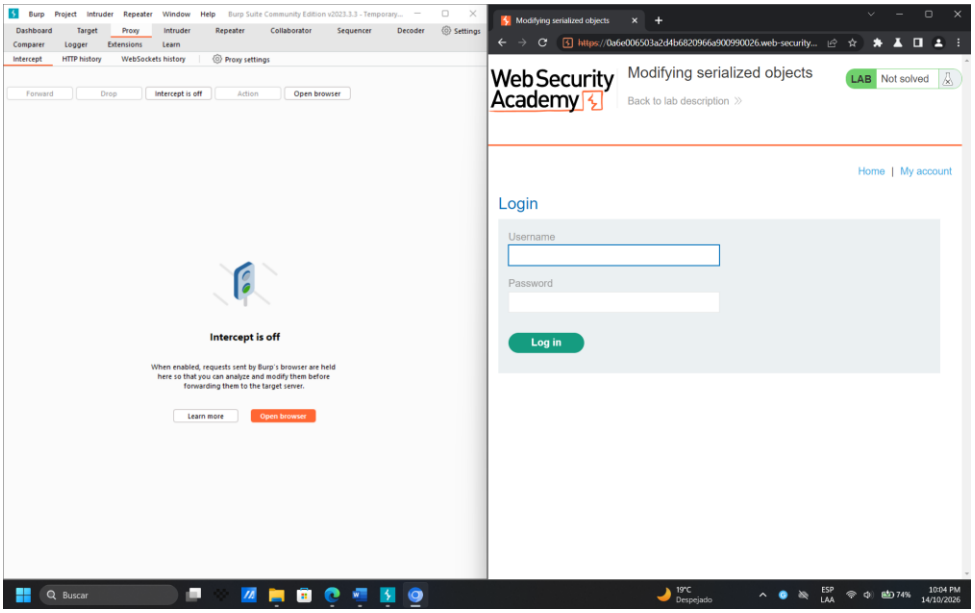
Copiamos el enlace que tenemos de nuestra guía de estudio para acceder al laboratorio:



Al darle clic en acceder al laboratorio este nos mandara al panel principal:



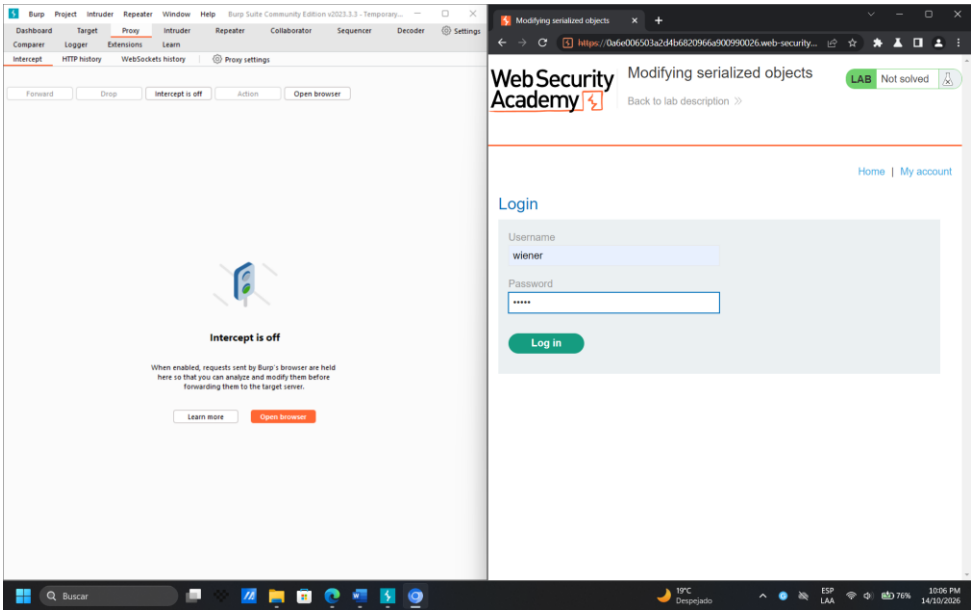
Ahora nos dirigimos al apartado de My Account:



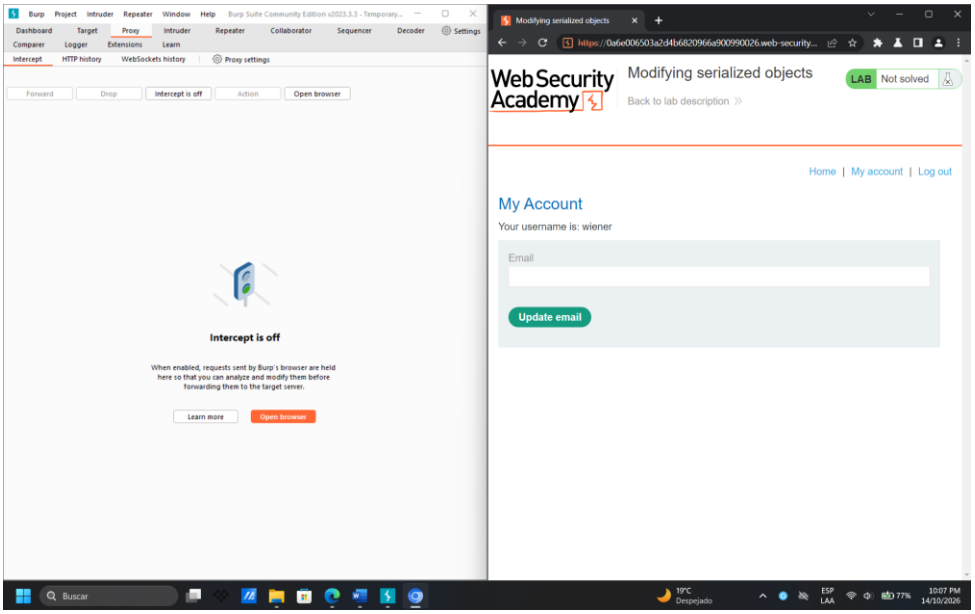
En este apartado tendremos que colocar los datos que se nos pidió anteriormente;

-**Usuario:** wiener.

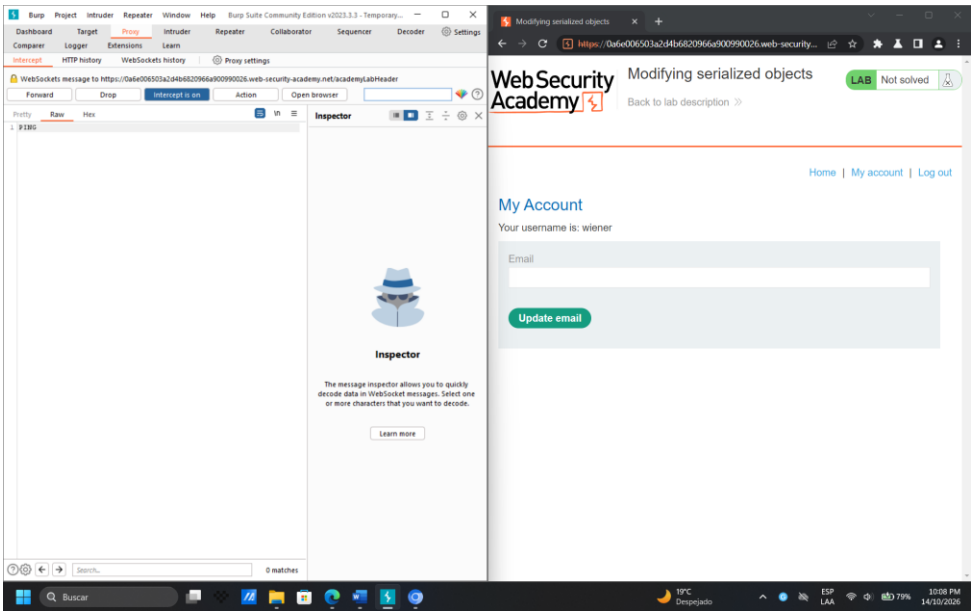
-**Contraseña:** Peter.



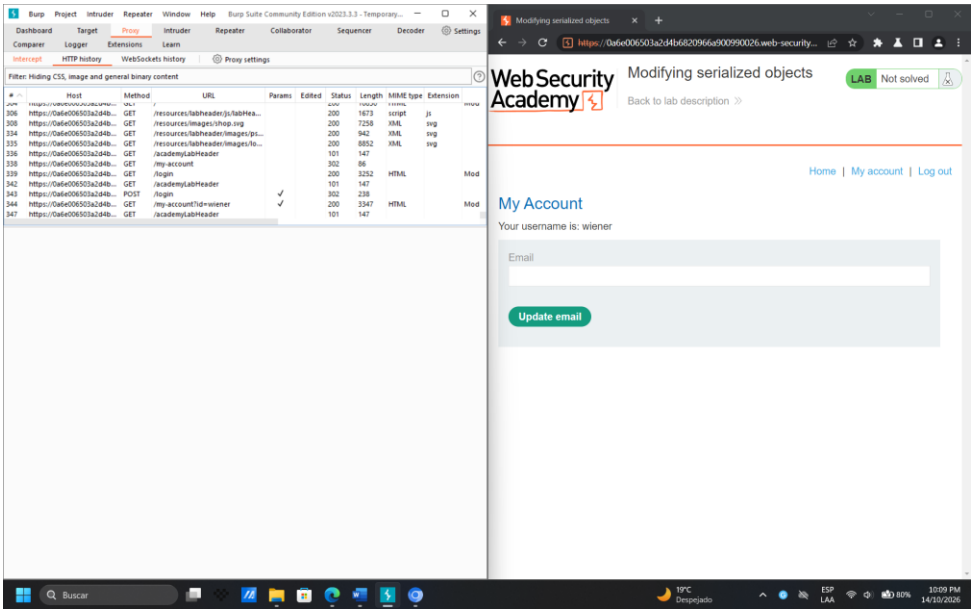
Al darle clic en Login nos permitirá ingresar a la página:



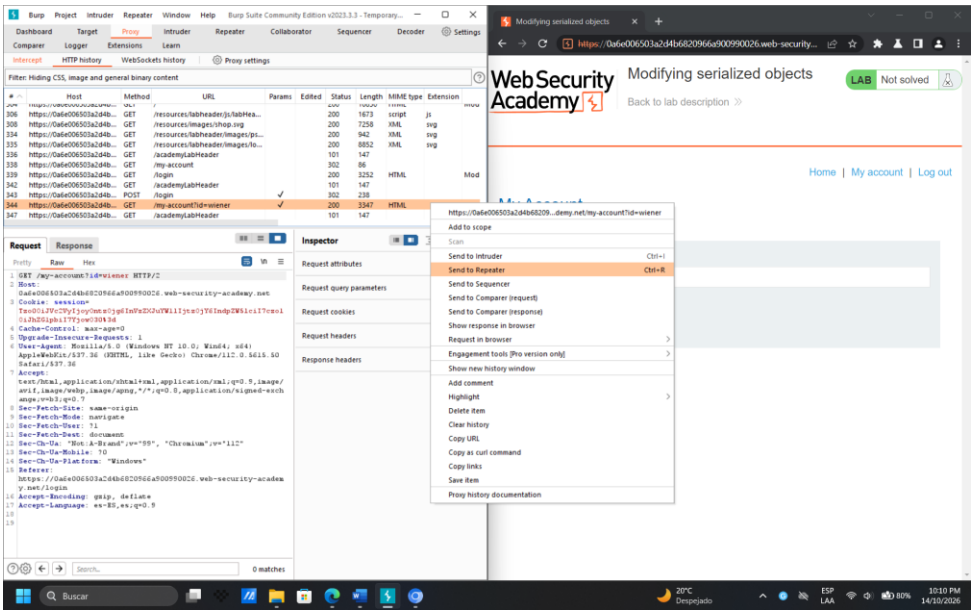
Es en este momento cuando nosotros tenemos que activar la intercepción de datos en Burp Suite:



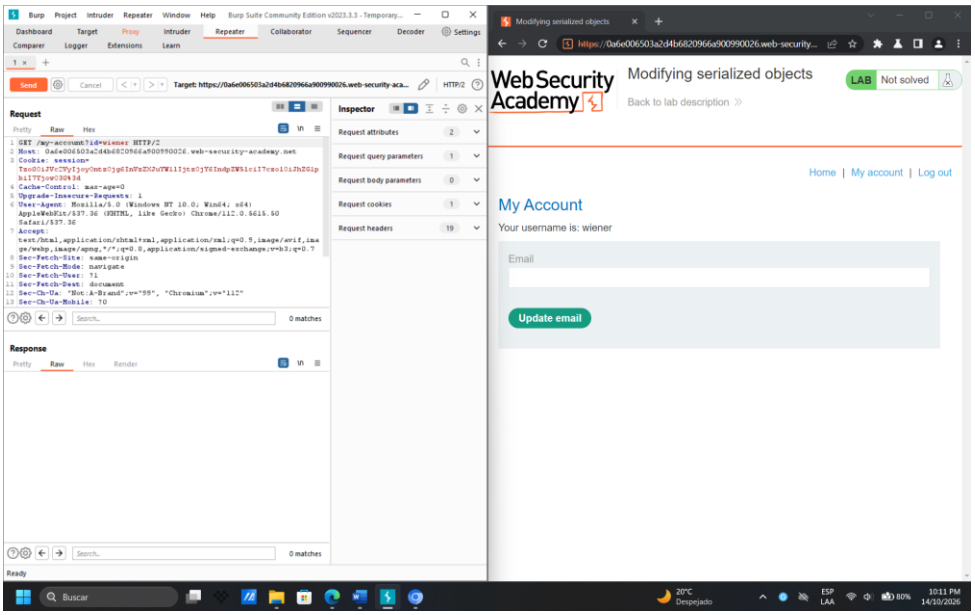
Nos dirigimos a HTTP History:



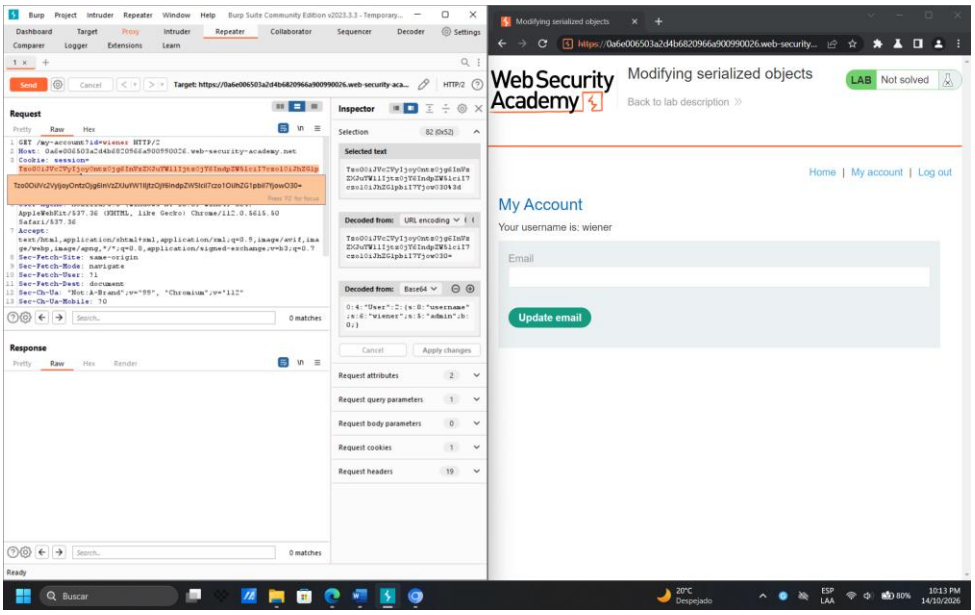
Seleccionamos el siguiente elemento, es indispensable ya que este nos marca las cookies para poder modificar; seguido de esto seleccionamos Send To Repeater:



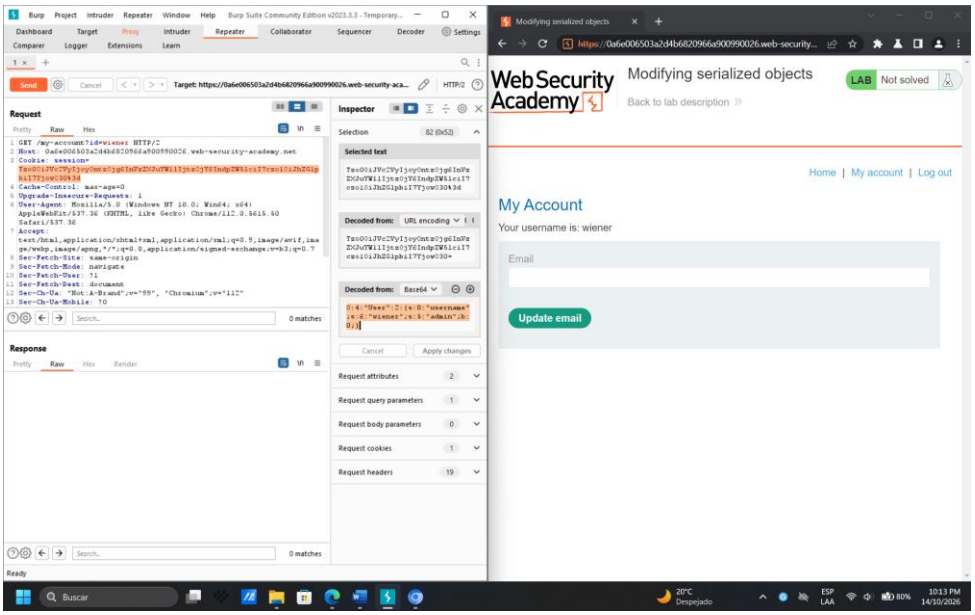
Una vez dentro de Repeater nos aparecerá lo siguiente:



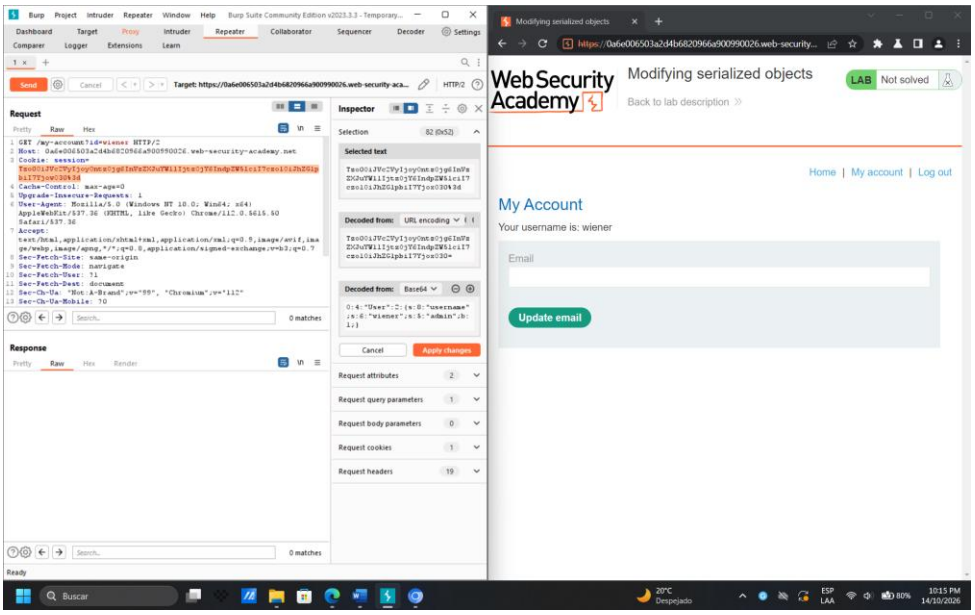
Es momento de modificar las cookies, para ello seleccionamos la información que está marcada en rojo:



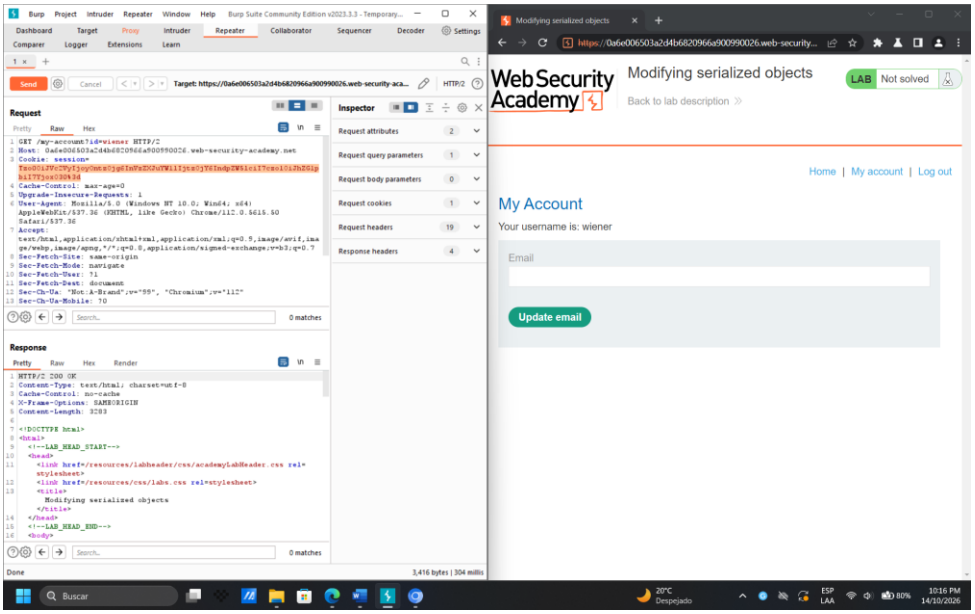
Del lado derecho tenemos un formato llamado Base64 que nos ayudara a modificar las cookies e ingresar al sitio como administrador:



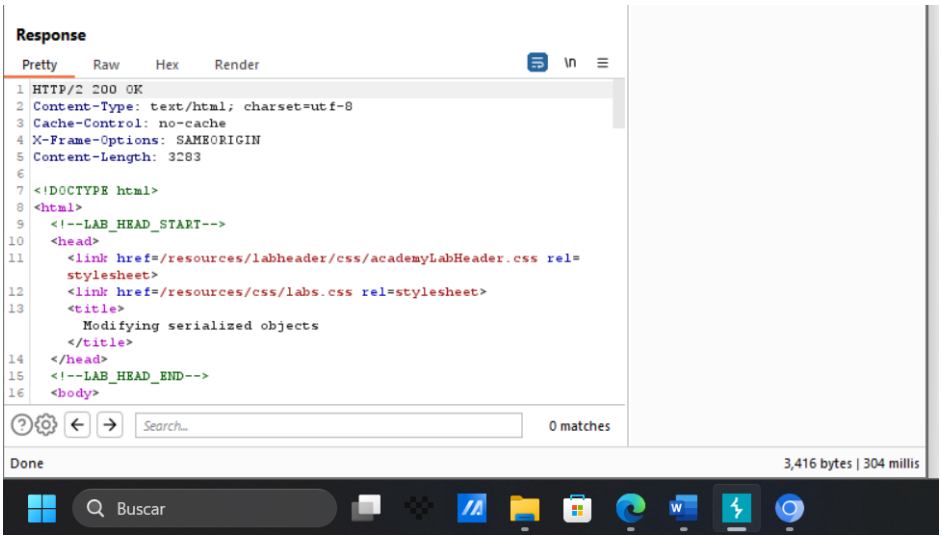
Para modificarlo es necesario observar la última línea de Base64; “admin” ;b: o ;}. El cero se cambia por un uno.



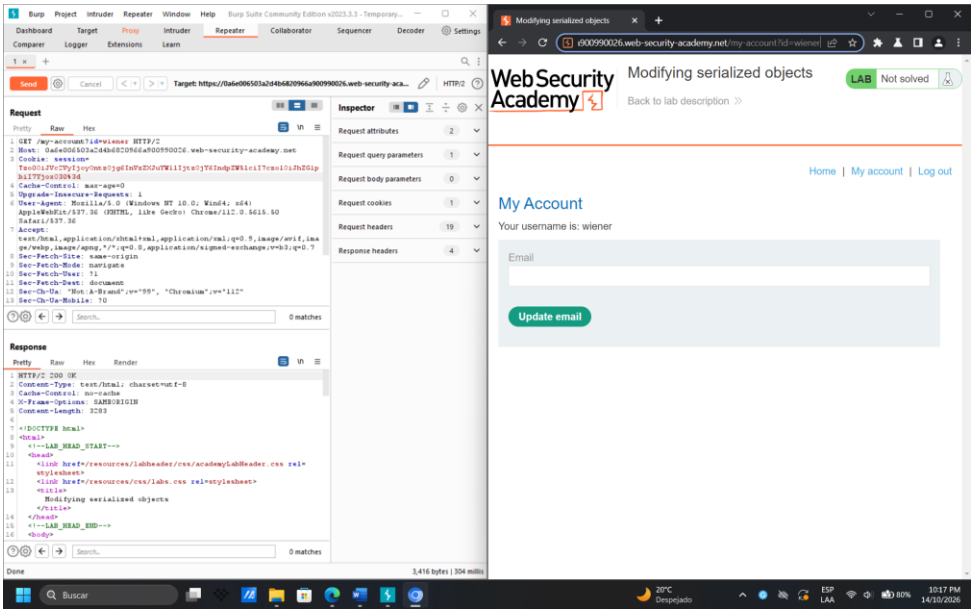
Aplicamos cambios y enviamos la modificación de las cookies:



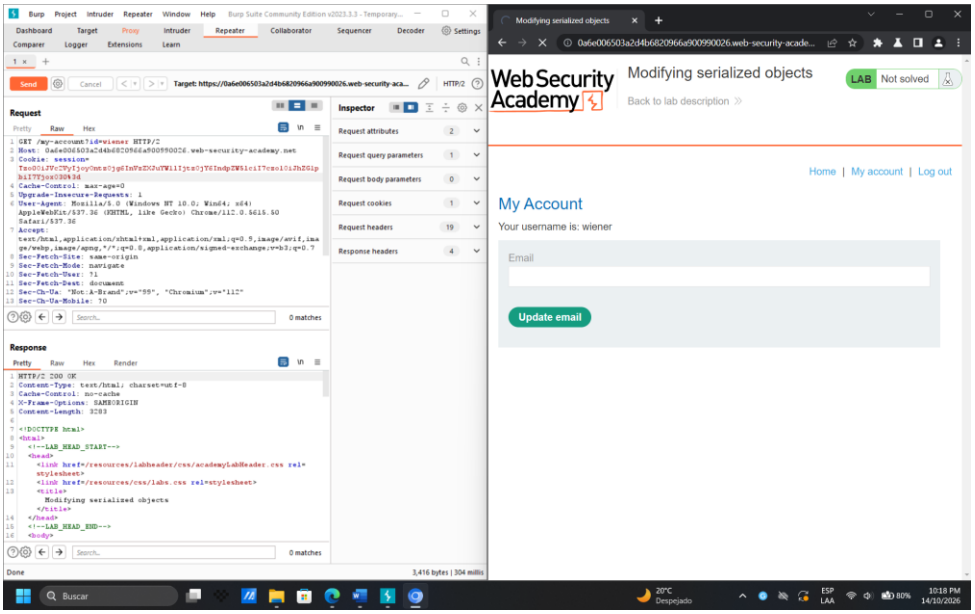
Que tenemos aquí, una respuesta. Esto quiere decir que los cambios se efectuaron con total normalidad gracias a HTTP/2 OK:



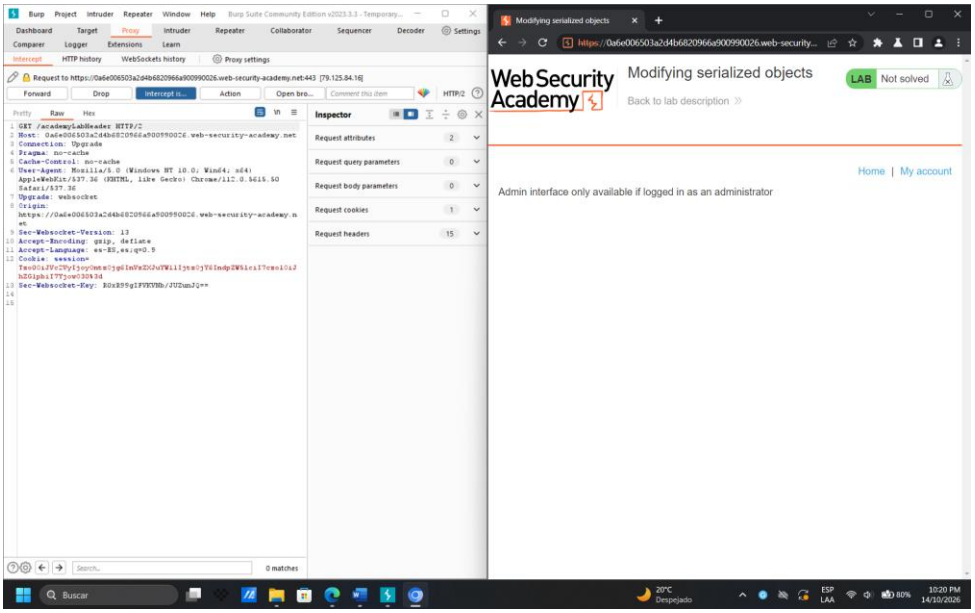
Ahora en mi URL debemos de cambiar después de la diagonal como admin:



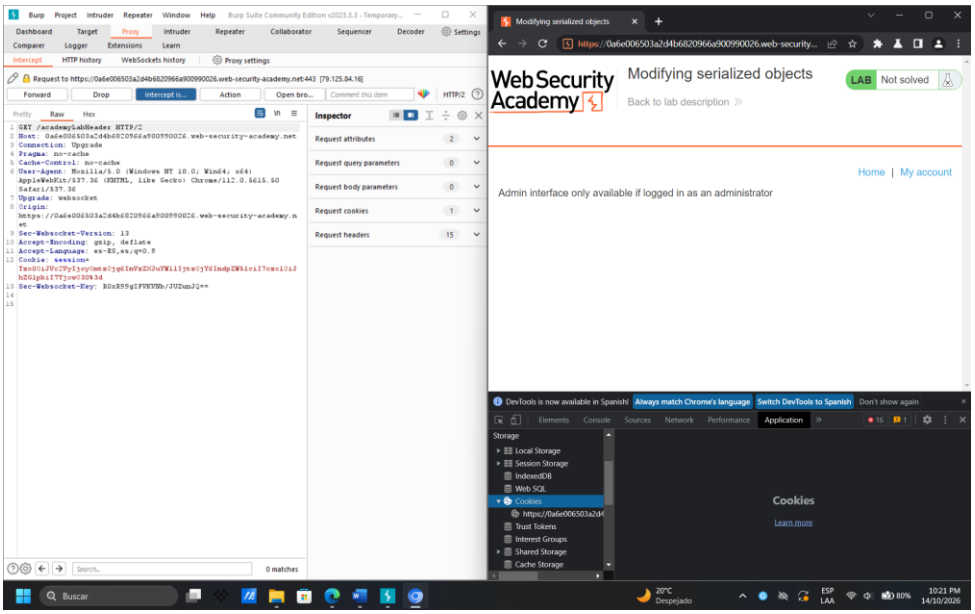
Si la página no carga no hay problema:



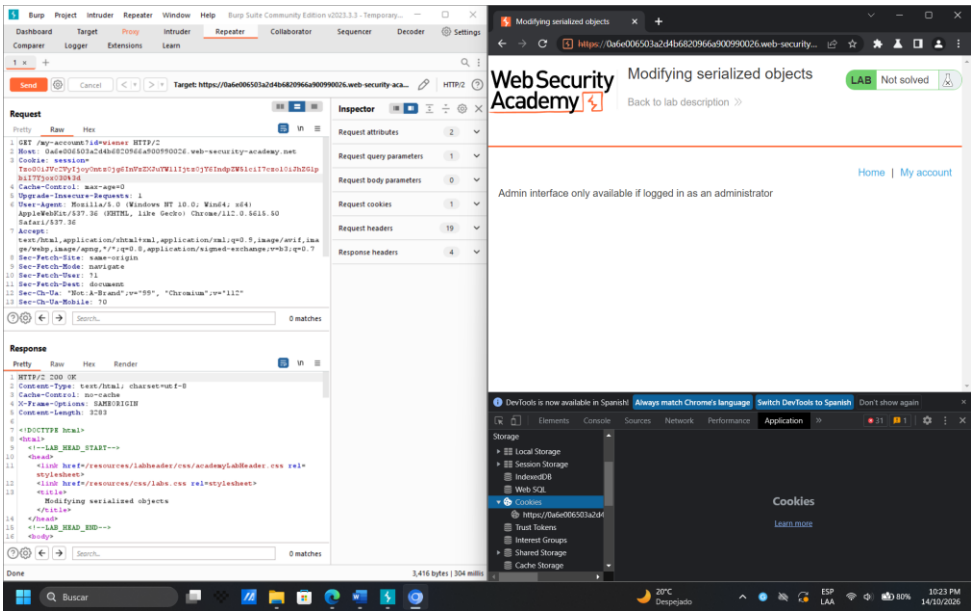
Nos dirigimos a Intercept y seleccionamos Forward; las veces necesarias hasta que la página cargue:



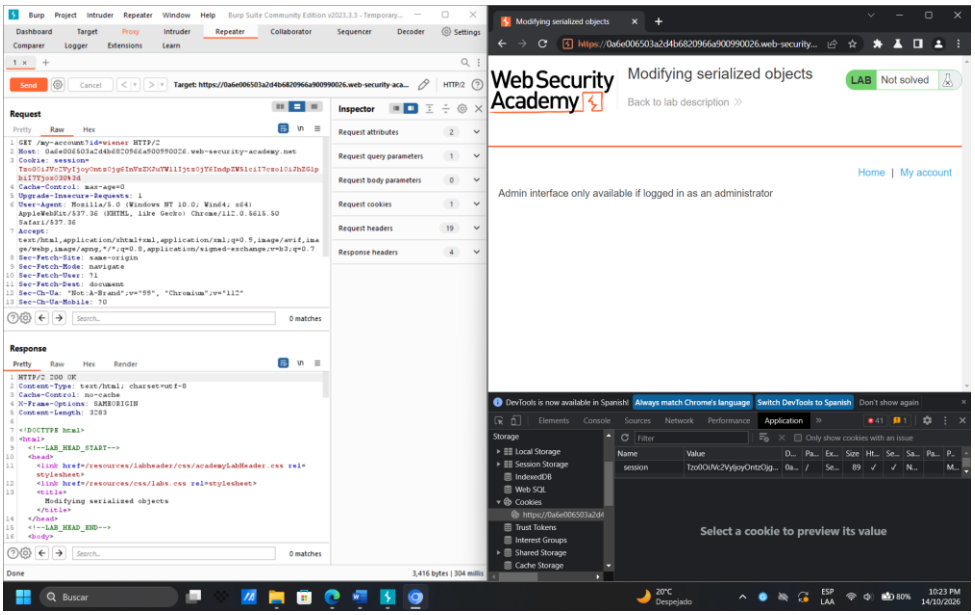
Sucedió algo curioso, no nos dio el acceso, para ello presionamos F12 donde se nos muestre la consola de la página web. Nos vamos a consola y cookies:



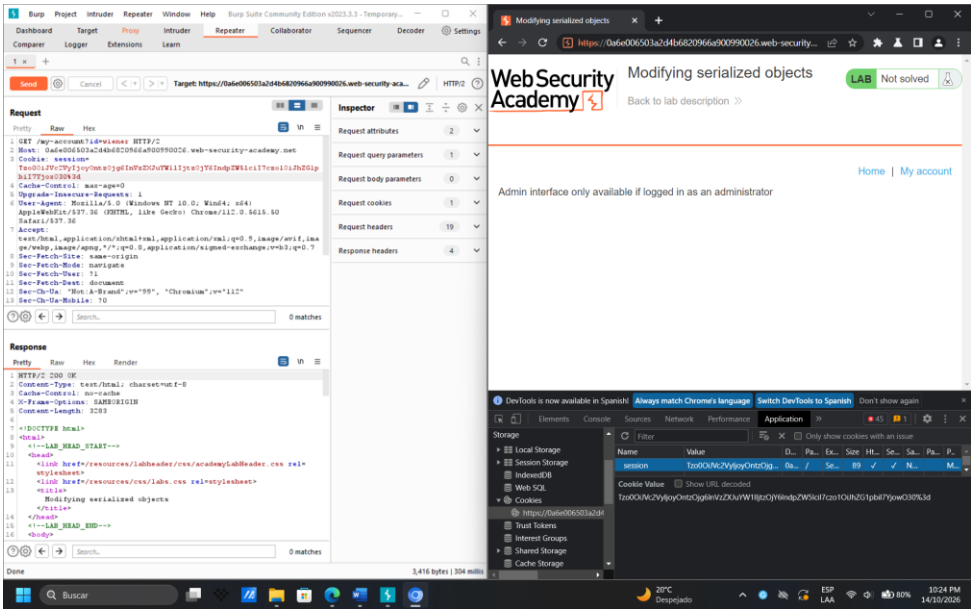
Del lado de Burp Suite nos vamos nuevamente donde teníamos nuestro código; en Repeater:



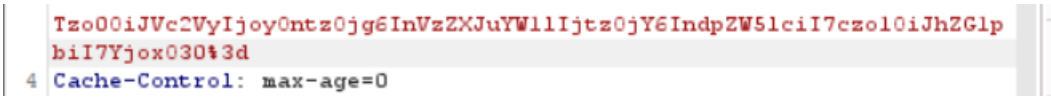
Ahora del lado del navegador seleccionamos la página que tenemos debajo de la URL:



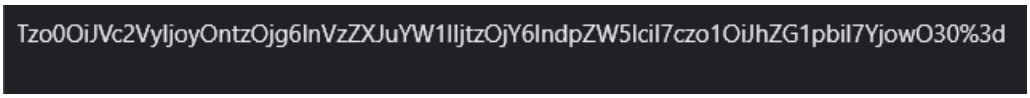
Es muy importante visualizar lo siguiente:



Haremos zoom para apreciar mejor; tenemos la captura de las cookies de Burp Suite:



Tenemos la captura de las cookies de nuestro navegador:

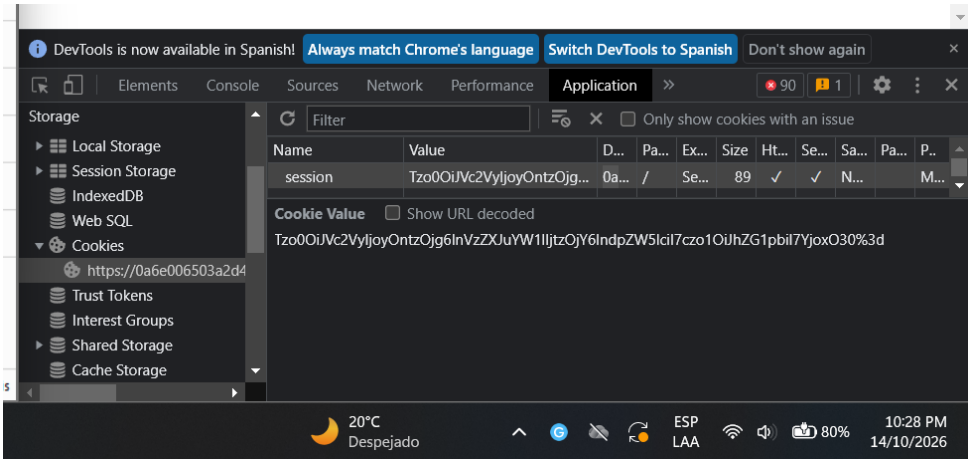


Existe una diferencia notable en este apartado:

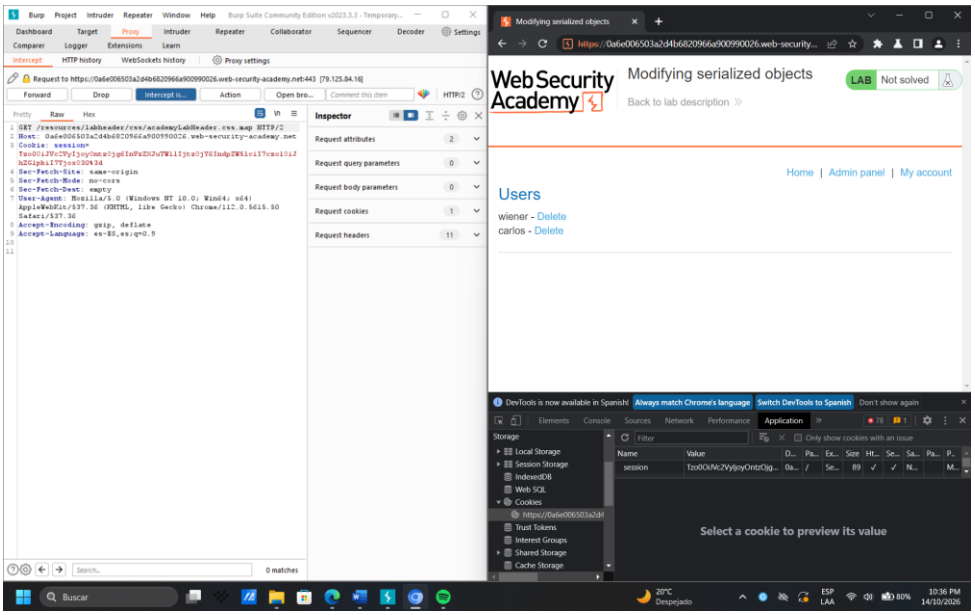




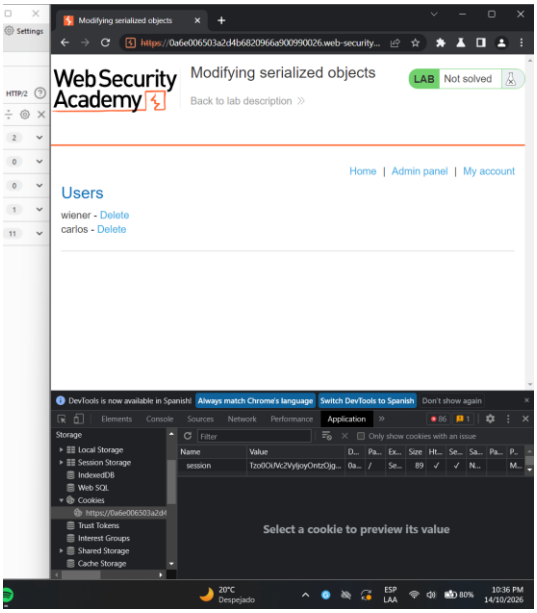
Esto nos indica que las cookies no son las mismas y que a pesar de que se generó la nueva aún no está instaurada en la página web. Pero es simple, solo pegamos las cookies de Burp Suite en la página web para sustituirla:



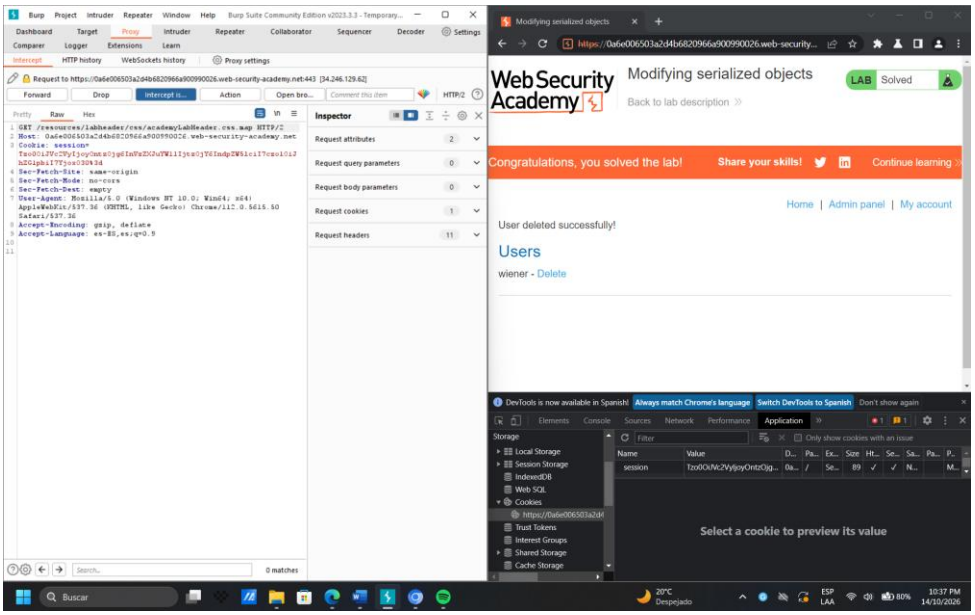
Ahora tenemos que actualizar el URL con “admin”:



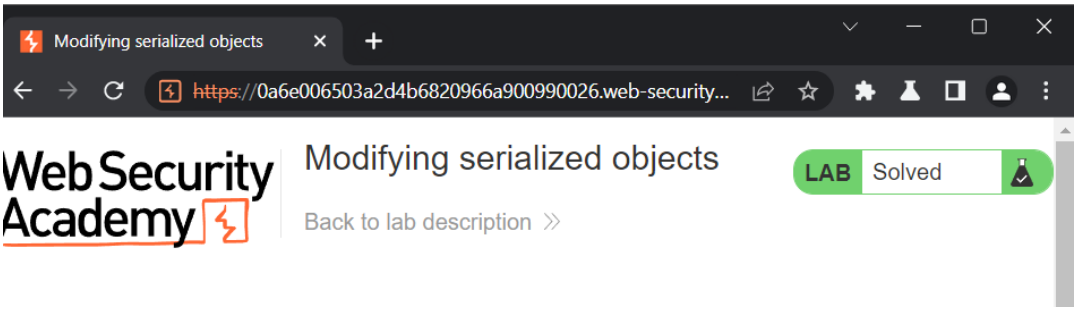
Como podemos apreciar ahora tenemos acceso a la parte de administración de la página:



Con esto podemos eliminar al usuario Carlos:



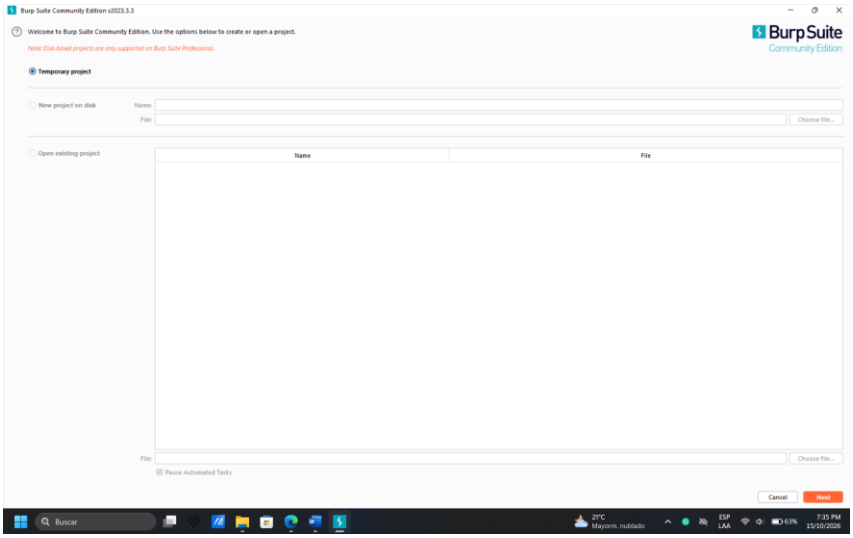
Con esto resolvimos el laboratorio que se nos pidió en la actividad:



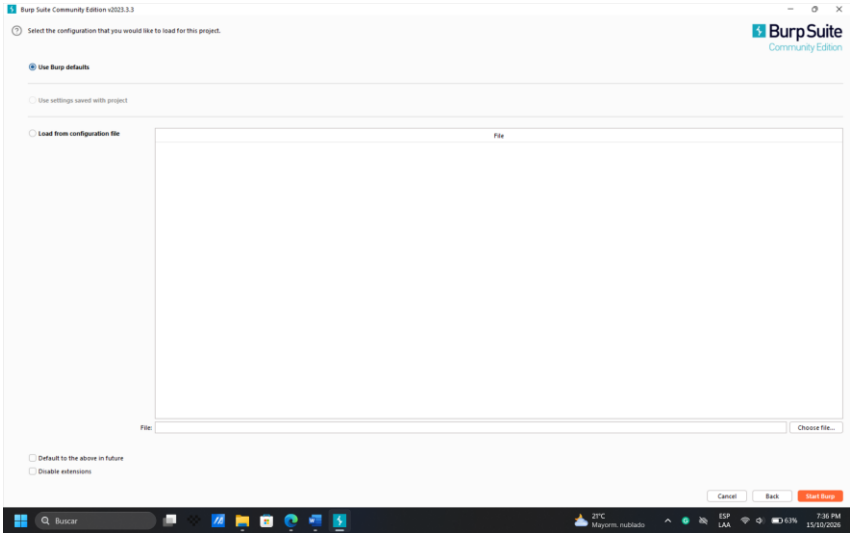
Etapa 3

Ataque al sitio

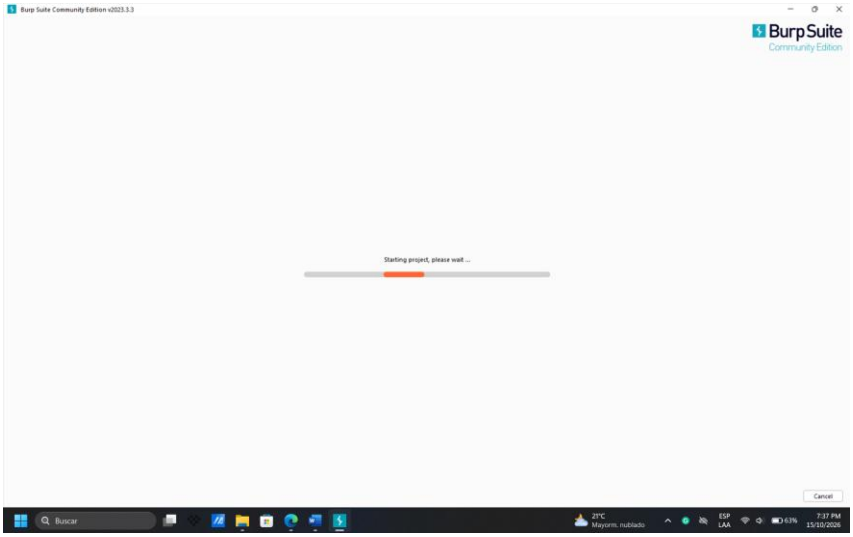
Empezamos abriendo Burp Suite en un proyecto temporal:



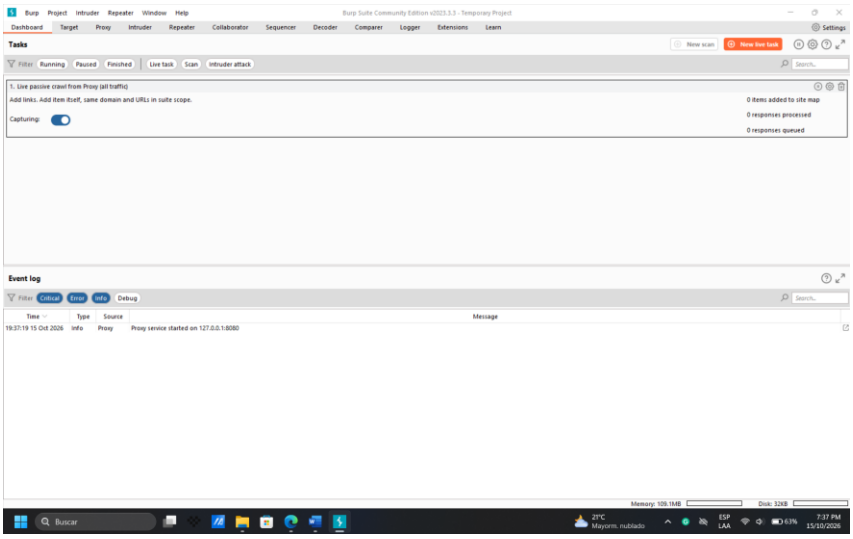
Damos clic en el botón de Next:



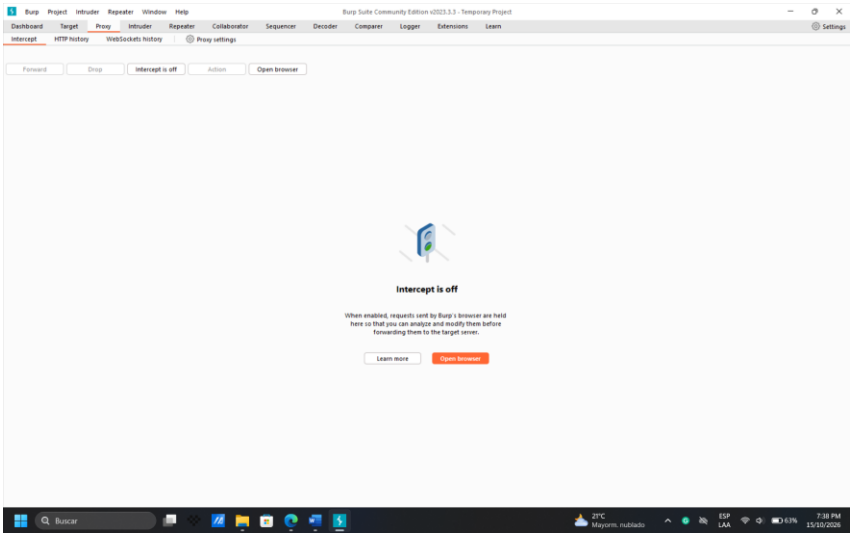
Seguido de esto al botón de Start Burp:



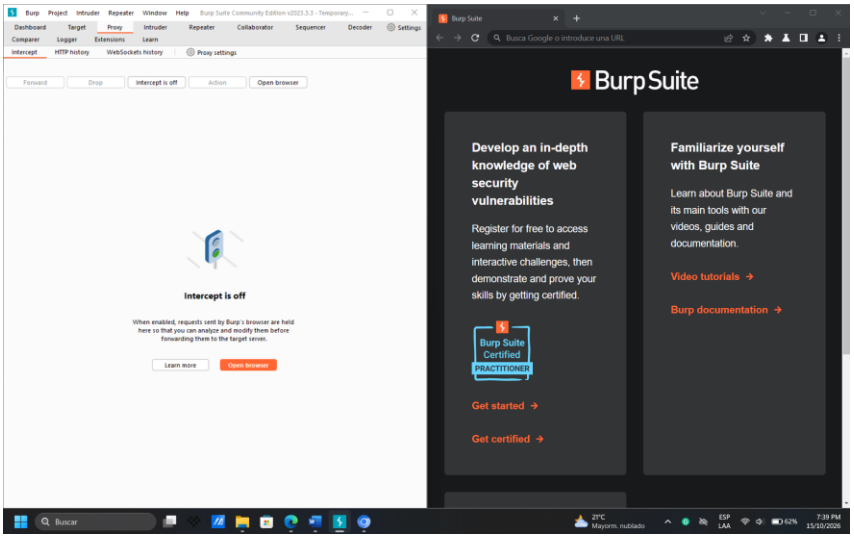
Al terminar de cargar nos mandara al panel principal:



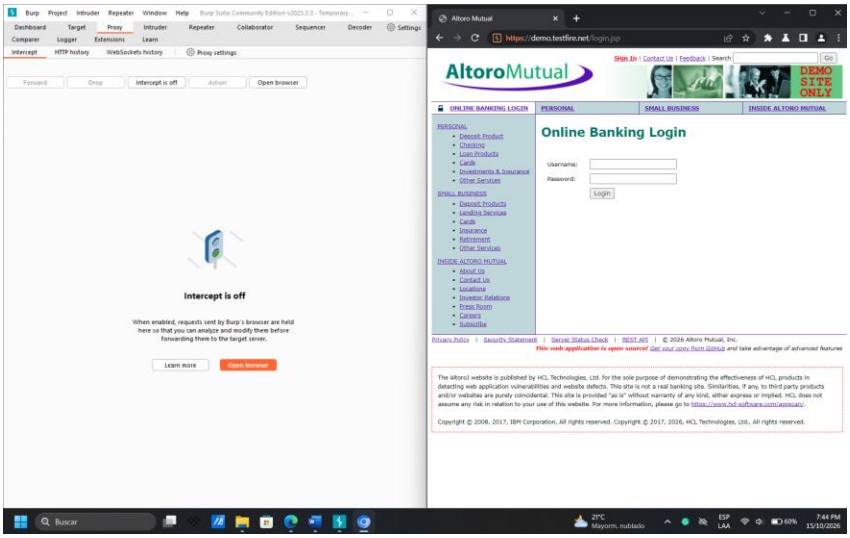
Nos vamos al apartado de Proxy:



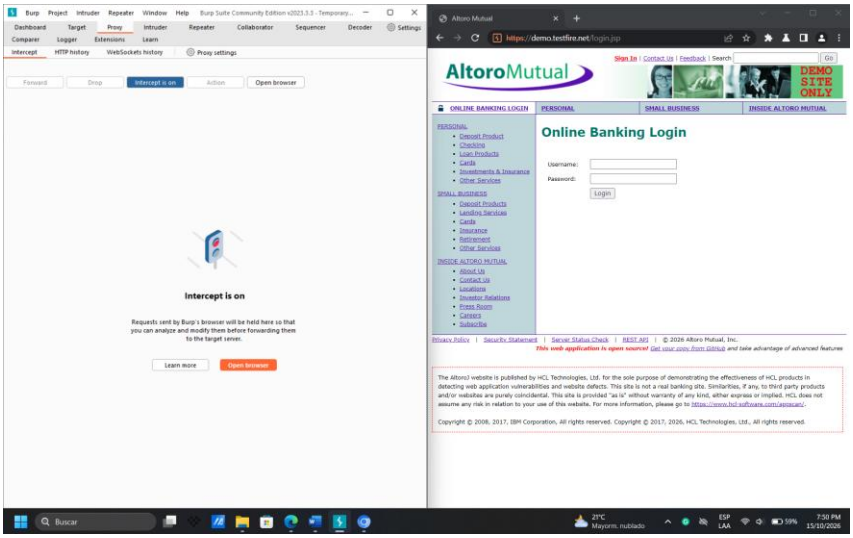
Procedemos a abrir el navegador:



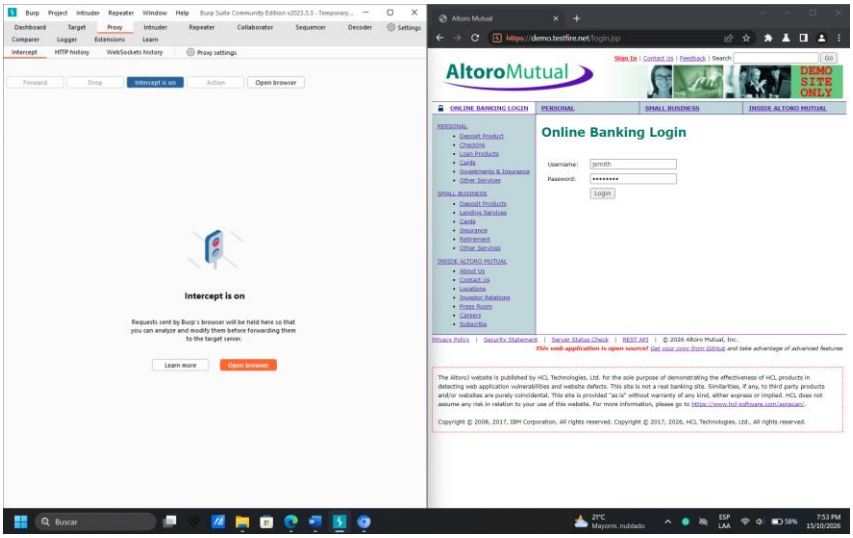
Vamos a colocar el link del sitio web que se usó en la actividad#1:



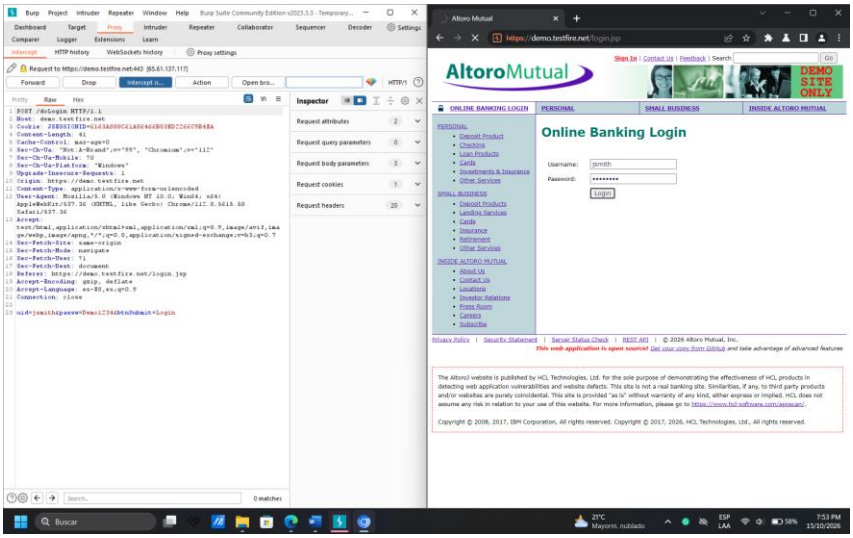
Vamos a activar en Burp Suite el interruptor:



Colocaremos las credenciales correctas:



Damos clic en Login pero este se quedara cargando:



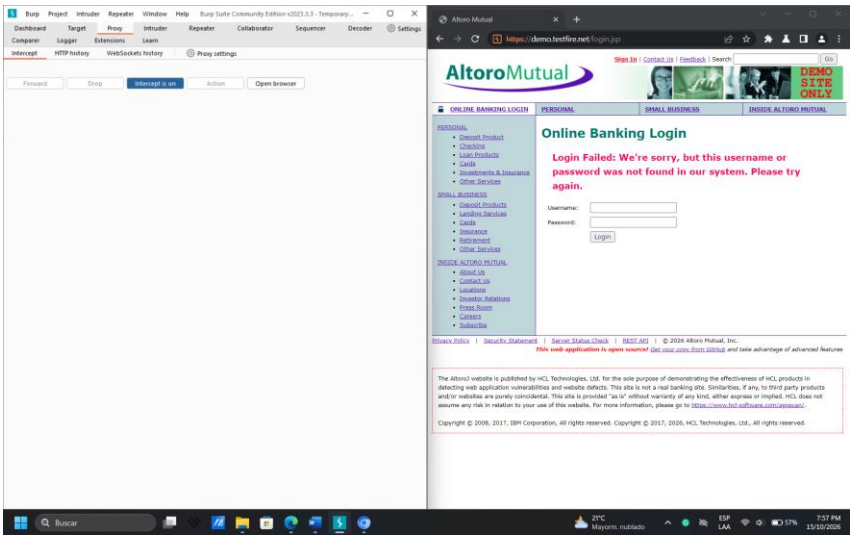
Vamos a modificar el correo y la contraseña para que este no acceda; la siguiente es la contraseña correcta:

```
21 Connection: close
22
23 uid=jsmith&passw=Demo1234&btnSubmit=Login
```

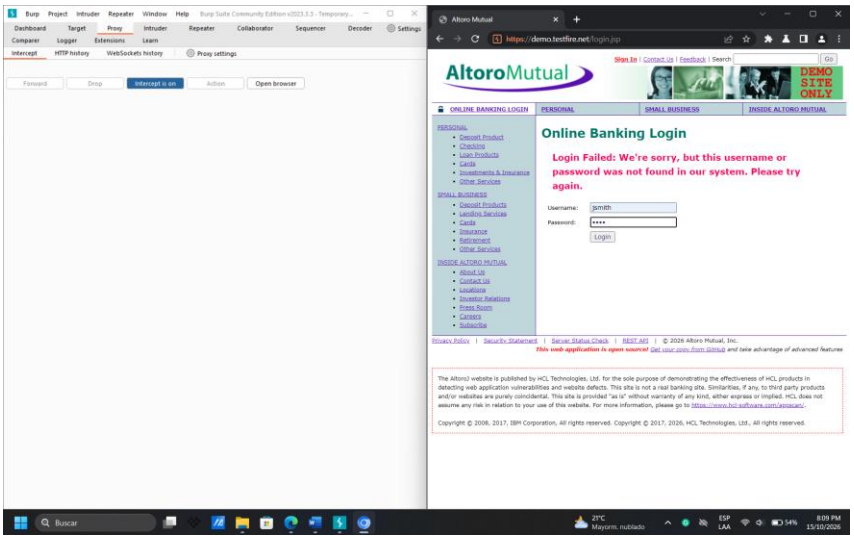
Realizamos una serie de modificaciones para que no coincida:

```
21 Connection: close
22
23 uid=jsmithd&passw=Demo12345&btnSubmit=Login
```

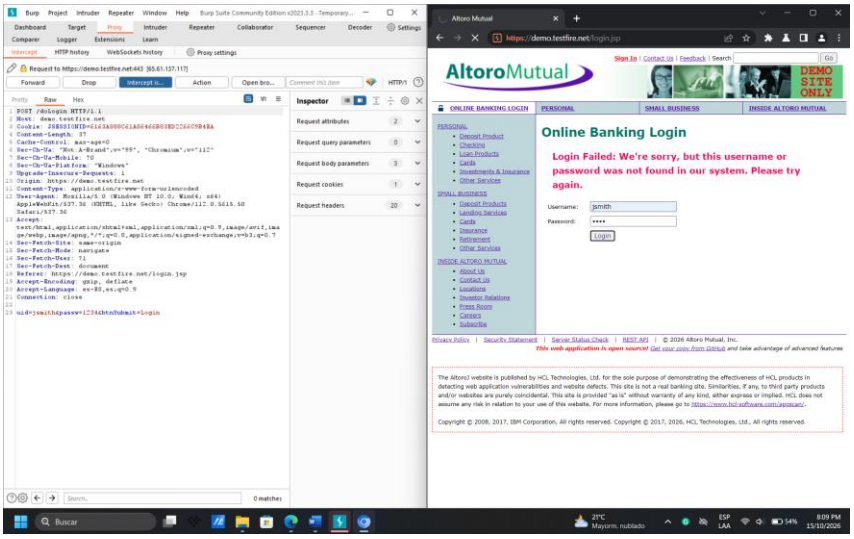
Seleccionamos el botón de Forward para ver que no nos dejara abrir la página por la modificación que se hizo: en lo anterior se modifico tanto el usuario como la contraseña:



Volveremos a hacer lo mismo con otra cuenta para que se vea que no es un caso aislado; colocamos los datos:



Iniciamos sesión:



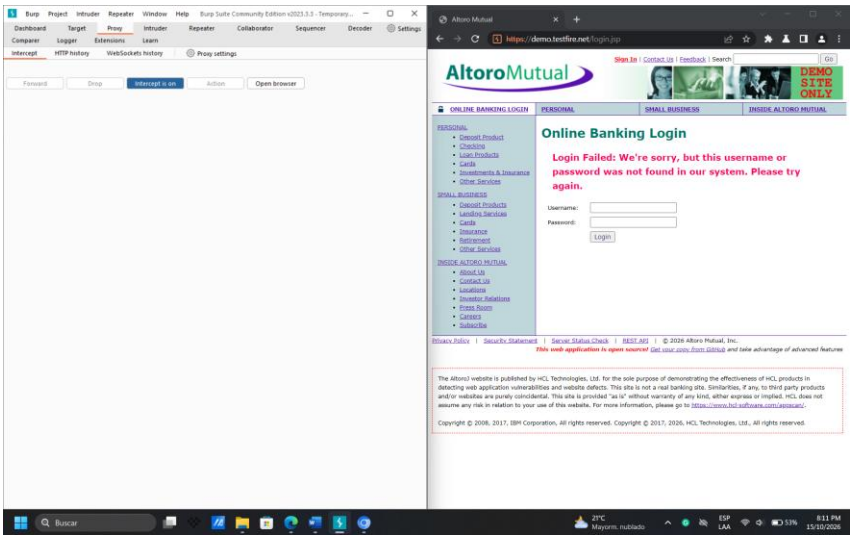
Tenemos los datos del usuario y contraseña:

```
21 Connection: close
22
23 uid=jsmith&passw=Demo1234&btnSubmit=Login
```

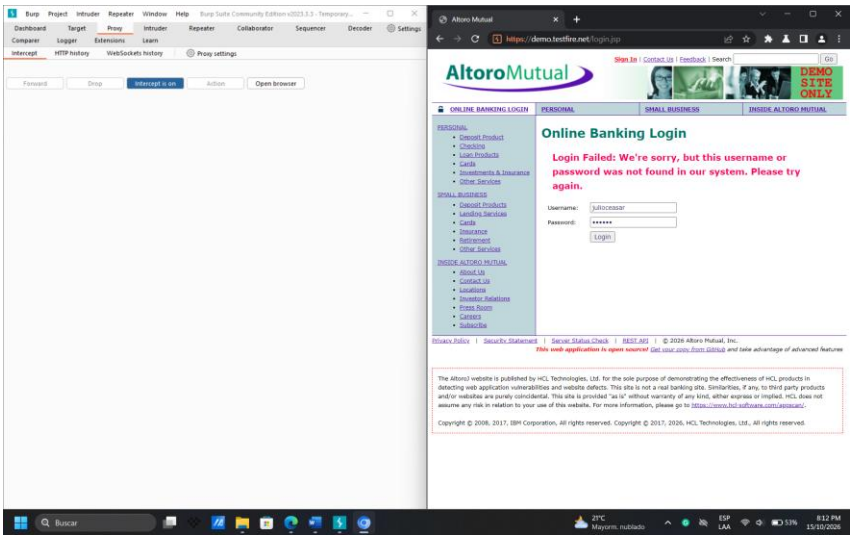
Se modifican:

```
21 Connection: close
22
23 uid=jsmithx&passw=1234x&btnSubmit=Login
```

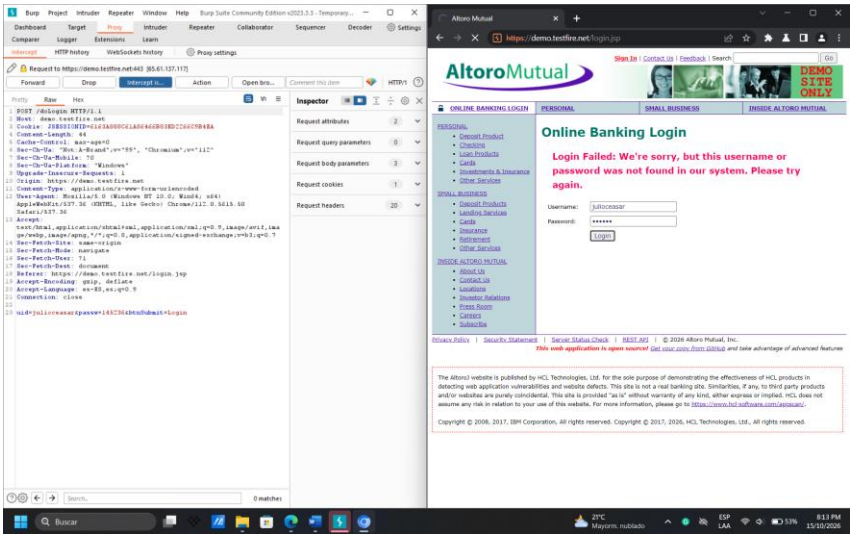
Damos clic en forward; sucede lo mismo:



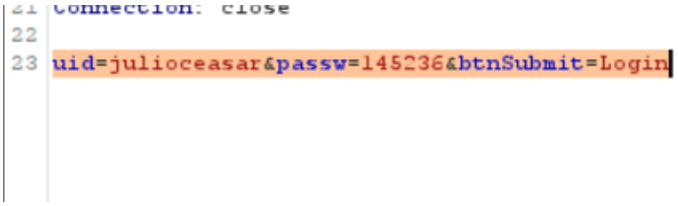
Haremos una prueba a la inversa: colocaremos datos incorrectos, pero modificaremos a los correctos para ver si se puede acceder:



Damos Login y modificamos los datos por los correctos:



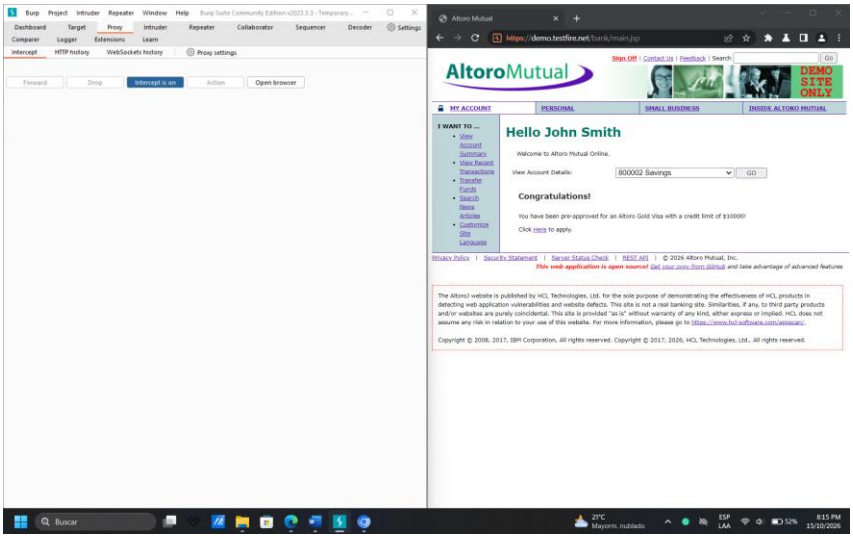
Usuario y contraseñas incorrectas:



Ahora la modificación de este:

```
22
23 uid=jsmith&passw=Demo1234&btnSubmit=Login
```

Damos Forward y en efecto, nos dejo ingresar a la siguiente pantalla:



Conclusión

Sin lugar a dudas, este ejercicio representa únicamente la superficie de un tema bastante extenso y profundo. No solo aborda vulnerabilidades en aplicaciones web, sino uno de los múltiples escenarios donde la seguridad puede verse comprometida. Asumir el rol de auditor permite identificar brechas por donde puede fugarse la información y comprender cómo operan los cibercriminales para la extorsión o el robo de datos.

Un ejemplo cotidiano ocurre en tiendas departamentales como Coppel, la cual cuenta tanto con sucursales físicas como con página web y aplicación móvil. Existen clientes que realizan sus pagos únicamente en tienda y desconocen las plataformas digitales; si un tercero con malas intenciones les comparte un enlace fraudulento prometiendo premios o la gestión de sus créditos, al ingresar sus datos en formularios falsos o sitios no cifrados, la información sensible pasa en texto plano o queda expuesta directamente al atacante, facilitando el robo de sus credenciales.

Link de GitHub

https://github.com/UZLOP984/Auditoria_informatica.git